

SEGURIDAD EN SISTEMAS DE INFORMACIÓN

Amenazas Zero-Day

Vulnerabilidades de día cero en la seguridad de la información

Caso de estudio: Stuxnet

Integrantes

Bruno Cascardó · Tomas Santiago Dragotta · Jano Martinez · Martin Quagliardi



El punto ciego de la ciberseguridad



Un Zero-Day explota un fallo que el fabricante todavía no conoce. No existe firma ni parche cuando ocurre el ataque.

El punto ciego de cualquier defensa basada en conocimiento previo.

0 días

para reaccionar antes de la explotación

→ origen del nombre “Zero-Day”

Tres etapas de una misma amenaza



Vulnerabilidad

Fallo desconocido para el fabricante.



Exploit

Código que aprovecha esa falla.



Ataque

El exploit usado contra un objetivo real.

Ciclo de vida de una vulnerabilidad



El período de mayor riesgo para cualquier organización.

CASO DE ESTUDIO

Stuxnet

La primera ciberarma conocida públicamente



Contexto y objetivo



Origen

Descubierto en 2010. Atribuido —sin confirmación oficial— a una operación conjunta de EE. UU. e Israel (“Operación Juegos Olímpicos”), iniciada hacia 2005.



Objetivo: Natanz (Irán)

Sabotaje de las centrifugadoras de enriquecimiento de uranio, sin ser detectado por los operadores.

~2.000

centrifugadoras
inutilizadas

~2 años

de retraso al programa
nuclear iraní

Cómo se propagó y actuó



Pese al aislamiento físico ("air-gapped") de la planta, el malware llegó por medios físicos.

Características de las amenazas Zero-Day



Desconocidas

Sin firma ni parche disponible.



Alto valor

Se guardan en secreto para no perder efectividad.



Difíciles de detectar

Ineficaces frente a antivirus por firmas.



Ventana crítica

Máximo riesgo antes del parche.



Objetivos de valor

Gobiernos, infraestructura crítica, grandes empresas.



Propagación masiva

Un exploit filtrado se reutiliza a gran escala.

Otros casos conocidos



EternalBlue / WannaCry

2017

200.000+

equipos en 150 países



Log4Shell

2021

Millones

de servidores expuestos



Pegasus

2021–22

0 clics

para infectar el dispositivo

Prevención y mitigación



Gestión de parches

Actualizar de inmediato.



EDR / XDR

Detectar comportamiento anómalo.



Zero Trust

Segmentar y limitar el acceso.



Sandboxing

Aislar archivos sospechosos.



Mínimo privilegio

Restringir permisos.



Bug bounty

Divulgación responsable.



Capacitación

Formar frente al phishing.



Respuesta a incidentes

Planes y backups.

CONCLUSIÓN

La pregunta ya no es si seremos blanco de un ataque Zero-Day, sino cuándo y qué tan preparados estaremos.

Defensa en profundidad: actualización constante, monitoreo de comportamiento y cultura de seguridad.

¡Gracias!